МИНИСТЕРСТВО НАУКИ И ВЫСШЕГО ОБРАЗОВАНИЯ РОССИЙСКОЙ ФЕДЕРАЦИИ

ФЕДЕРАЛЬНОЕ ГОСУДАРСТВЕННОЕ БЮДЖЕТНОЕ
ОБРАЗОВАТЕЛЬНОЕ УЧРЕЖДЕНИЕ
ВЫСШЕГО ОБРАЗОВАНИЯ
«НОВОСИБИРСКИЙ ГОСУДАРСТВЕННЫЙ ТЕХНИЧЕСКИЙ УНИВЕРСИТЕТ»

Кафедра защиты информации



ЛАБОРАТОРНАЯ РАБОТА №1

по дисциплине: ***«Безопасность систем баз данных»***

Вариант: 12. Защита БД систем цифровой идентификации граждан – защита биометрических данных, электронных паспортов и единого цифрового профиля с контролем доступа по уровням доверия

Выполнил:

Студент гр. «АБ-420», «АВТФ»

Корецкий П. С.

« » 2026г

_____

(подпись)

Проверил:

Старший преподаватель ЗИ

Питько Я. А.

« » 2026г

_____

(подпись)

Новосибирск 2026

ВВЕДЕНИЕ

Современные государственные и корпоративные информационные системы цифровой идентификации граждан аккумулируют колоссальные объемы высокочувствительных сведений: биометрические векторы (фотоизображения лиц, отпечатки пальцев, сканы радужной оболочки глаз), реквизиты электронных паспортов со смарт-чипами, страховые номера (СНИЛС), ИНН и юридические согласия на передачу сведений в ведомственные контуры. Компрометация подобных сведений или неправомерный доступ к ним несут критические риски компрометации цифровой личности гражданина, финансового мошенничества и утечки охраняемой законом тайны.

В соответствии с требованиями стандартов информационной безопасности и технического задания на лабораторную работу № 1, проектируемая база данных должна обеспечивать строгую изоляцию бизнес-логики от служебных журналов аудита, минимизацию привилегий пользователей по принципу Least Privilege, разделение обязанностей администраторов (Separation of Duties) и динамический контроль доступа к объектам цифрового профиля в зависимости от подтвержденного уровня доверия (Trust Level).

Цель работы: спроектировать доменную реляционную схему системы цифровой идентификации граждан, провести классификацию хранимых данных, реализовать воспроизводимую схему DDL через контейнеризированные миграции и настроить комплексную подсистему безопасности с разделением обязанностей, политиками RLS, аудитом и логированием сессий.

Задачи работы:

1. Разработать ER-диаграмму базы данных с указанием ключей, связей 1:N и M:N, ограничений целостности и доменов значений;
2. Провести классификацию всех атрибутов базы данных по четырем уровням: Public, Internal, Confidential, Restricted, составив матрицы классификации;
3. Реализовать DDL-скрипты создания 14 таблиц в изолированных схемах ref, app, audit, stg с первичными/внешними ключами, проверками CHECK, уникальностью и индексами;

4. Сгенерировать репрезентативный набор тестовых данных с шифрованием чувствительных атрибутов функциями pgcrypto;
5. Спроектировать и внедрить ролевую модель безопасности с разделением обязанностей (app_reader, app_writer, app_owner, auditor, ddl_admin, dml_admin, security_admin), отключением публичных прав (PUBLIC) и настройкой DEFAULT PRIVILEGES;
6. Разработать политики построчного разграничения доступа (Row Level Security) на основе подтвержденных уровней доверия и согласий граждан;
7. Реализовать подсистему триггерного DML-аудита и функцию фиксации пользовательских подключений в таблице audit.login_log;
8. Подготовить воспроизводимое окружение на базе Docker Compose, golang-migrate и Makefile, а также провести сценарии верификации настроек безопасности.

Решение поставленных задач позволяет сформировать защищенную архитектуру цифрового профиля с высоким уровнем отказоустойчивости и разграничения полномочий.

ER-модель и классификация

Цель работы: спроектировать доменную схему, классифицировать данные и настроить доступ с разделением обязанностей.

Была сформирована ER-диаграмма домена с указанием ключей и связей на основе варианта «Защита БД систем цифровой идентификации граждан – защита биометрических данных, электронных паспортов и единого цифрового профиля с контролем доступа по уровням доверия» (Рисунок 1).

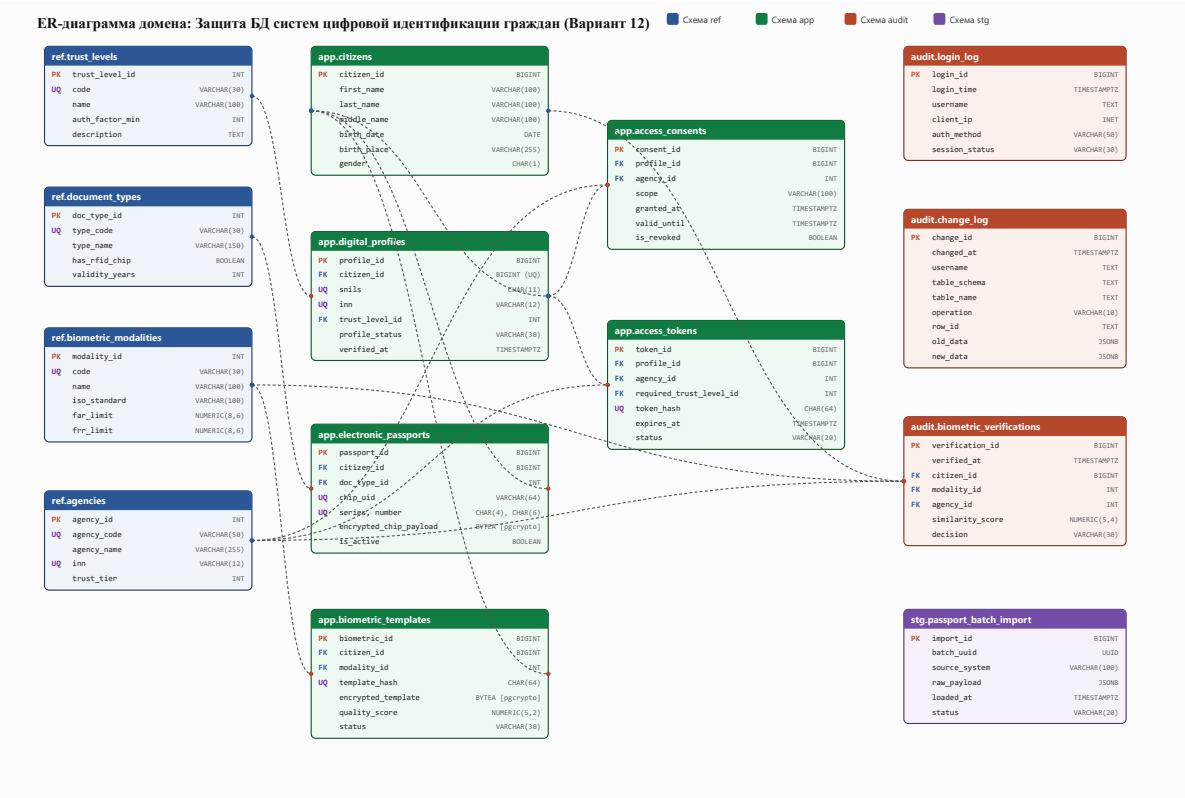


Рисунок 1 – ER-диаграмма

На ER-диаграмме представлены основные сущности базы данных системы цифровой идентификации граждан и связи между ними. Таблицы разделены по схемам ref, app, audit и stg.

Связи между таблицами реализованы с помощью первичных и внешних ключей. Отношение многие-ко-многим между цифровыми профилями и ведомствами-потребителями реализовано через таблицу app.access_consents и сессионные токены app.access_tokens.

Была выполнена классификация данных на 4 уровнях: Public (открытые данные), Internal (внутренние служебные данные), Confidential (данные

ограниченного доступа), Restricted (чувствительные данные). По результатам классификации были сформированы матрицы (таблицы) «колонка – класс» (Таблица 1 – 14).

Поле	Класс данных
trust_level_id	Internal
code	Public
name	Public
auth_factor_min	Internal
description	Public
is_active	Internal

Таблица 1 – Классификация данных в таблице ref.trust_levels

Поле	Класс данных
doc_type_id	Internal
type_code	Public
type_name	Public
has_rfid_chip	Internal
validity_years	Public

Таблица 2 – Классификация данных в таблице ref.document_types

Поле	Класс данных
modality_id	Internal
code	Public
name	Public
iso_standard	Public
far_limit	Internal
frr_limit	Internal

Таблица 3 – Классификация данных в таблице ref.biometric_modalities

Поле	Класс данных
agency_id	Internal
agency_code	Public
agency_name	Public
inn	Public
ogrn	Public
trust_tier	Internal
is_active	Internal

Таблица 4 – Классификация данных в таблице ref.agencies

Поле	Класс данных
citizen_id	Internal
first_name	Confidential
last_name	Confidential
middle_name	Confidential
birth_date	Confidential
birth_place	Confidential
gender	Confidential
created_at	Internal

Таблица 5 – Классификация данных в таблице app.citizens

Поле	Класс данных
profile_id	Internal
citizen_id	Internal
snils	Confidential
inn	Confidential
trust_level_id	Internal
profile_status	Internal
verified_at	Internal
created_at	Internal

Таблица 6 – Классификация данных в таблице app.digital_profiles

Поле	Класс данных
passport_id	Internal
citizen_id	Internal
doc_type_id	Internal
chip_uid	Restricted
series	Restricted
number	Restricted
issue_date	Confidential
expiry_date	Confidential
issuing_authority_code	Internal
encrypted_chip_payload	Restricted
is_active	Internal

Таблица 7 – Классификация данных в таблице app.electronic_passports

Поле	Класс данных
biometric_id	Internal
citizen_id	Internal
modality_id	Internal
template_hash	Restricted
encrypted_template	Restricted
quality_score	Confidential
capture_device_id	Internal
registered_at	Internal
status	Internal

Таблица 8 – Классификация данных в таблице app.biometric_templates

Поле	Класс данных
consent_id	Internal
profile_id	Internal
agency_id	Internal
scope	Confidential
granted_at	Internal
valid_until	Internal
is_revoked	Internal
consent_signature	Restricted

Таблица 9 – Классификация данных в таблице app.access_consents

Поле	Класс данных
token_id	Internal
profile_id	Internal
agency_id	Internal
required_trust_level_id	Internal
token_hash	Restricted
issued_at	Internal
expires_at	Internal
status	Internal

Таблица 10 – Классификация данных в таблице app.access_tokens

Поле	Класс данных
login_id	Internal
login_time	Internal
username	Confidential
client_ip	Confidential
client_port	Internal
auth_method	Internal
session_status	Internal

Таблица 11 – Классификация данных в таблице audit.login_log

Поле	Класс данных
change_id	Internal
changed_at	Internal
username	Confidential
table_schema	Internal
table_name	Internal
operation	Internal
row_id	Confidential
old_data	Restricted
new_data	Restricted

Таблица 12 – Классификация данных в таблице audit.change_log

Поле	Класс данных
verification_id	Internal
verified_at	Internal
citizen_id	Internal
modality_id	Internal
agency_id	Internal
similarity_score	Confidential
decision	Internal
client_ip	Confidential

Таблица 13 – Классификация данных в таблице audit.biometric_verifications

Поле	Класс данных
import_id	Internal
batch_uuid	Internal
source_system	Internal
raw_payload	Restricted
loaded_at	Internal
status	Internal
error_message	Internal

Таблица 14 – Классификация данных в таблице stg.passport_batch_import

Таким образом, проведенная классификация данных позволила детально распределить атрибуты сущностей по классам безопасности и определить целесообразность применения механизмов криптографической защиты и ролевого доступа.

DDL и схемы

Были созданы схемы: app (таблицы с основными данными), ref (таблицы-справочники), audit (таблицы с журналами аудита), stg (таблица с временными объектами). Соотношение схем к таблицам приведено в таблице 15.

Схема	Таблица
app	citizens
	digital_profiles
	electronic_passports
	biometric_templates
	access_consents
	access_tokens
ref	trust_levels
	document_types
	biometric_modalities
	agencies
audit	login_log
	change_log
	biometric_verifications
stg	passport_batch_import

Таблица 15 – Соотношение схем к таблицам

Содержимое всех таблиц приведено ниже (Таблица 16 – 29).

Атрибут	Название	Тип	Вид	Домен	Ключ	Ограничения
trust_level_id	Идентификатор уровня	INT	Простой однозначный	Натур. полож. числа	PK	NOT NULL
code	Кодовое имя уровня	VARCHAR(30)	Простой однозначный	Латиница	UQ	NOT NULL, CHECK (ANONYMOUS, SIMPLIFIED, STANDARD, CONFIRMED, BIOMETRIC)
name	Наименование уровня	VARCHAR(100)	Простой однозначный	Кириллица	-	NOT NULL
auth_factor_min	Мин. факторов	INT	Простой однозначный	Целые числа	-	NOT NULL, CHECK (1..4)
description	Описание доступа	TEXT	Составной многозначный	Кириллица	-	NOT NULL
is_active	Флаг активности	BOOLEAN	Простой однозначный	Логический	-	NOT NULL, DEFAULT TRUE

Таблица 16 – ref.trust_levels (уровни доверия цифрового профиля)

Атрибут	Название	Тип	Вид	Домен	Ключ	Ограничения
doc_type_id	Идентификатор типа	INT	Простой однозначный	Натур. полож. числа	PK	GENERATED ALWAYS AS IDENTITY, NOT NULL
type_code	Системный код типа	VARCHAR(30)	Простой однозначный	Латиница	UQ	NOT NULL, CHECK (E_PASSPORT, DIGITAL_ID_CARD, FOREIGN_PASSPORT, RESIDENCE_PERMIT)
type_name	Название документа	VARCHAR(150)	Простой однозначный	Кириллица	-	NOT NULL
has_rfid_chip	Наличие RFID-чипа	BOOLEAN	Простой однозначный	Логический	-	NOT NULL, DEFAULT TRUE
validity_years	Срок действия (лет)	INT	Простой однозначный	Натур. числа	-	NOT NULL, CHECK (validity_years > 0)

Таблица 17 – ref.document_types (типы удостоверяющих документов)

Атрибут	Название	Тип	Вид	Домен	Ключ	Ограничения
modality_id	Идентификатор модальности	INT	Простой однозначный	Натур. полож. числа	PK	GENERATED ALWAYS AS IDENTITY, NOT NULL
code	Код модальности	VARCHAR(30)	Простой однозначный	Латиница	UQ	NOT NULL, CHECK (FACE_2D, FACE_3D, FINGERPRINT_SLAP, FINGERPRINT_ROLL, IRIS, VOICE)
name	Наименование параметра	VARCHAR(100)	Простой однозначный	Кириллица	-	NOT NULL
iso_standard	Стандарт ISO/ГОСТ	VARCHAR(100)	Простой однозначный	Латиница + цифры	-	NOT NULL
far_limit	Предел FAR	NUMERIC(8,6)	Простой однозначный	Дробные числа	-	NOT NULL, CHECK (far_limit > 0 AND far_limit < 1)
frr_limit	Предел FRR	NUMERIC(8,6)	Простой однозначный	Дробные числа	-	NOT NULL, CHECK (frr_limit > 0 AND frr_limit < 1)

Таблица 18 – ref.biometric_modalities (биометрические модальности)

Атрибут	Название	Тип	Вид	Домен	Ключ	Ограничения
agency_id	Идентификатор ведомства	INT	Простой однозначный	Натур. полож. числа	PK	GENERATED ALWAYS AS IDENTITY, NOT NULL
agency_code	Системный код	VARCHAR(50)	Простой однозначный	Латиница	UQ	NOT NULL
agency_name	Официальное имя	VARCHAR(255)	Составной однозначный	Кириллица	-	NOT NULL
inn	ИНН организации	VARCHAR(12)	Простой однозначный	Цифры (10-12)	UQ	NOT NULL, CHECK (length(inn) IN (10, 12))
ogrn	ОГРН организации	VARCHAR(15)	Простой однозначный	Цифры (13-15)	UQ	NOT NULL, CHECK (length(ogrn) IN (13, 15))
trust_tier	Уровень доверия	INT	Простой однозначный	Целые числа	-	NOT NULL, CHECK (trust_tier BETWEEN 1 AND 5)
is_active	Флаг активности	BOOLEAN	Простой однозначный	Логический	-	NOT NULL, DEFAULT TRUE

Таблица 19 – ref.agencies (ведомства и организации-потребители)

Атрибут	Название	Тип	Вид	Домен	Ключ	Ограничения
citizen_id	Идентификатор гражданина	BIGINT	Простой однозначный	Натур. полож. числа	PK	GENERATED ALWAYS AS IDENTITY, NOT NULL
first_name	Имя гражданина	VARCHAR(100)	Простой однозначный	Кириллица	-	NOT NULL, CHECK (length >= 1)
last_name	Фамилия гражданина	VARCHAR(100)	Простой однозначный	Кириллица	-	NOT NULL, CHECK (length >= 1)
middle_name	Отчество гражданина	VARCHAR(100)	Простой однозначный	Кириллица	-	Допускается NULL
birth_date	Дата рождения	DATE	Составной однозначный	Дата	-	NOT NULL, CHECK (birth_date > „1900-01-01“ AND <= CURRENT_DATE)
birth_place	Место рождения	VARCHAR(255)	Составной однозначный	Кириллица	-	NOT NULL
gender	Пол гражданина	CHAR(1)	Простой однозначный	Символ	-	NOT NULL, CHECK (gender IN („M“, „F“))
created_at	Время регистрации	TIMESTAMPTZ	Составной однозначный	Дата и время	-	NOT NULL, DEFAULT CURRENT_TIMESTAMP

Таблица 20 – app.citizens (реестр граждан)

Атрибут	Название	Тип	Вид	Домен	Ключ	Ограничения
profile_id	Идентификатор профиля	BIGINT	Простой однозначный	Натур. полож. числа	PK	GENERATED ALWAYS AS IDENTITY, NOT NULL
citizen_id	Владелец профиля	BIGINT	Простой однозначный	Натур. полож. числа	FK, UQ	NOT NULL, FK на app.citizens(citizen_id) ON DELETE RESTRICT
snils	СНИЛС гражданина	CHAR(11)	Простой однозначный	Цифры (11)	UQ	NOT NULL, CHECK (snils „^\[0-9\]{11}$“)
inn	ИНН физлица	VARCHAR(12)	Простой однозначный	Цифры (12)	UQ	NOT NULL, CHECK (length(inn) = 12)
trust_level_id	Уровень доверия	INT	Простой однозначный	Целые числа	FK	NOT NULL, FK на ref.trust_levels(trust_level_id)
profile_status	Статус профиля	VARCHAR(30)	Простой однозначный	Латиница	-	NOT NULL, DEFAULT „ACTIVE“, CHECK (PENDING, ACTIVE, SUSPENDED, BLOCKED, REVOKED)
verified_at	Дата подтверждения	TIMESTAMPTZ	Составной однозначный	Дата и время	-	Допускается NULL
created_at	Время создания	TIMESTAMPTZ	Составной однозначный	Дата и время	-	NOT NULL, DEFAULT CURRENT_TIMESTAMP

Таблица 21 – app.digital_profiles (единый цифровой профиль)

Атрибут	Название	Тип	Вид	Домен	Ключ	Ограничения
passport_id	Идентификатор паспорта	BIGINT	Простой однозначный	Натур. полож. числа	PK	GENERATED ALWAYS AS IDENTITY, NOT NULL
citizen_id	Владелец паспорта	BIGINT	Простой однозначный	Натур. полож. числа	FK	NOT NULL, FK на app.citizens(citizen_id)
doc_type_id	Тип документа	INT	Простой однозначный	Натур. полож. числа	FK	NOT NULL, FK на ref.document_types(doc_type_id)
chip_uid	Аппаратный UID чипа	VARCHAR(64)	Простой однозначный	HEX-строка	UQ	NOT NULL, CHECK (chip_uid „^\[A-Fa-f0-9\]+ $“)
series	Серия бланка	CHAR(4)	Простой однозначный	Цифры (4)	-	NOT NULL, CHECK (series „^\[0-9\]{4}$“)
number	Номер бланка	CHAR(6)	Простой однозначный	Цифры (6)	-	NOT NULL, CHECK (number „^\[0-9\]{6}$“), UNIQUE(series, number)
issue_date	Дата выдачи	DATE	Составной однозначный	Дата	-	NOT NULL, CHECK (issue_date <= CURRENT_DATE)
expiry_date	Дата окончания	DATE	Составной однозначный	Дата	-	NOT NULL, CHECK (expiry_date > issue_date)
issuing_authority_code	Код подразделения	VARCHAR(10)	Простой однозначный	Цифры + дефис	-	NOT NULL, CHECK (issuing_authority_code „^\[0-9\]{3}-\[0-9\]{3}$“)
encrypted_chip_payload	Зашифрованный чип	BYTEA	Составной однозначный	Двоичные данные	-	NOT NULL, шифрование pgcrypto
is_active	Флаг валидности	BOOLEAN	Простой однозначный	Логический	-	NOT NULL, DEFAULT TRUE

Таблица 22 – app.electronic_passports (электронные паспорта)

Атрибут	Название	Тип	Вид	Домен	Ключ	Ограничения
biometric_id	Идентификатор биометрии	BIGINT	Простой однозначный	Натур. полож. числа	PK	GENERATED ALWAYS AS IDENTITY, NOT NULL
citizen_id	Гражданин-субъект	BIGINT	Простой однозначный	Натур. полож. числа	FK	NOT NULL, FK на app.citizens(citizen_id)
modality_id	Модальность биометрии	INT	Простой однозначный	Натур. полож. числа	FK	NOT NULL, FK на ref.biometric_modalities(modality_id)
template_hash	SHA-256 хеш вектора	CHAR(64)	Простой однозначный	HEX-строка (64)	UQ	NOT NULL, CHECK (template_hash „^\[A-Fa-f0-9\]{64}$“), UNIQUE(citizen_id, modality_id)
encrypted_template	Зашифрованный биовектор	BYTEA	Составной однозначный	Двоичные данные	-	NOT NULL, шифрование pgcrypto
quality_score	Оценка качества	NUMERIC(5,2)	Простой однозначный	Дробные числа (0-100)	-	NOT NULL, CHECK (quality_score BETWEEN 0.00 AND 100.00)
capture_device_id	ID сканера/ камеры	VARCHAR(100)	Простой однозначный	Латиница + цифры	-	NOT NULL
status	Статус валидности	VARCHAR(30)	Простой однозначный	Латиница	-	NOT NULL, DEFAULT „VERIFIED“, CHECK (PENDING, VERIFIED, DEPRECATED, REVOKED)

Таблица 23 – app.biometric_templates (биометрические шаблоны)

Атрибут	Название	Тип	Вид	Домен	Ключ	Ограничения
consent_id	Идентификатор согласия	BIGINT	Простой однозначный	Натур. полож. числа	PK	GENERATED ALWAYS AS IDENTITY, NOT NULL
profile_id	Цифровой профиль	BIGINT	Простой однозначный	Натур. полож. числа	FK	NOT NULL, FK на app.digital_profiles(profile_id)
agency_id	Орган/банк-получатель	INT	Простой однозначный	Натур. полож. числа	FK	NOT NULL, FK на ref.agencies(agency_id)
scope	Область полномочий	VARCHAR(100)	Простой однозначный	Латиница	-	NOT NULL, CHECK (scope IN („PROFILE_READ“, „DOCS_VERIFY“, „BIOMETRIC_MATCH“, „FULL_ACCESS“)), UNIQUE(profile_id, agency_id, scope)
granted_at	Время выдачи согласия	TIMESTAMPTZ	Составной однозначный	Дата и время	-	NOT NULL, DEFAULT CURRENT_TIMESTAMP
valid_until	Срок действия согласия	TIMESTAMPTZ	Составной однозначный	Дата и время	-	NOT NULL, CHECK (valid_until > granted_at)
is_revoked	Признак отзыва	BOOLEAN	Простой однозначный	Логический	-	NOT NULL, DEFAULT FALSE
consent_signature	ЭЦП согласия	TEXT	Составной многозначный	ЭЦП/Base64	-	NOT NULL

Таблица 24 – app.access_consents (согласия гражданина)

Атрибут	Название	Тип	Вид	Домен	Ключ	Ограничения
token_id	Идентификатор токена	BIGINT	Простой однозначный	Натур. полож. числа	PK	GENERATED ALWAYS AS IDENTITY, NOT NULL
profile_id	Целевой профиль	BIGINT	Простой однозначный	Натур. полож. числа	FK	NOT NULL, FK на app.digital_profiles(profile_id)
agency_id	Запросившее ведомство	INT	Простой однозначный	Натур. полож. числа	FK	NOT NULL, FK на ref.agencies(agency_id)
required_trust_level_id	Требуемый уровень	INT	Простой однозначный	Целые числа	FK	NOT NULL, FK на ref.trust_levels(trust_level_id)
token_hash	Хеш токена	CHAR(64)	Простой однозначный	HEX-строка (64)	UQ	NOT NULL
issued_at	Время генерации токена	TIMESTAMPTZ	Составной однозначный	Дата и время	-	NOT NULL, DEFAULT CURRENT_TIMESTAMP
expires_at	Время истечения	TIMESTAMPTZ	Составной однозначный	Дата и время	-	NOT NULL, CHECK (expires_at > issued_at)
status	Статус токена	VARCHAR(20)	Простой однозначный	Латиница	-	NOT NULL, DEFAULT „ACTIVE“, CHECK (ACTIVE, EXPIRED, REVOKED)

Таблица 25 – app.access_tokens (сессионные токены доступа)

Атрибут	Название	Тип	Вид	Домен	Ключ	Ограничения
login_id	Идентификатор входа	BIGINT	Простой однозначный	Натур. полож. числа	PK	GENERATED ALWAYS AS IDENTITY, NOT NULL
login_time	Время подключения	TIMESTAMPTZ	Составной однозначный	Дата и время	-	NOT NULL, DEFAULT CURRENT_TIMESTAMP
username	Имя роли/ пользователя	TEXT	Простой однозначный	Латиница	-	NOT NULL
client_ip	IP-адрес клиента	INET	Прост./Сост. однозначный	IP-адрес	-	Допускается NULL
client_port	Сетевой порт	INT	Простой однозначный	Целые числа	-	Допускается NULL
auth_method	Метод проверки	VARCHAR(50)	Простой однозначный	Латиница	-	NOT NULL, DEFAULT „PASSWORD“
session_status	Статус подключения	VARCHAR(30)	Простой однозначный	Латиница	-	NOT NULL, DEFAULT „SUCCESS“, CHECK (SUCCESS, DENIED, TERMINATED)

Таблица 26 – audit.login_log (журнал подключений пользователей)

Атрибут	Название	Тип	Вид	Домен	Ключ	Ограничения
change_id	Идентификатор события	BIGINT	Простой однозначный	Натур. полож. числа	PK	GENERATED ALWAYS AS IDENTITY, NOT NULL
changed_at	Время изменения	TIMESTAMPTZ	Составной однозначный	Дата и время	-	NOT NULL, DEFAULT CURRENT_TIMESTAMP
username	Инициатор транзакции	TEXT	Простой однозначный	Латиница	-	NOT NULL
table_schema	Схема таблицы	TEXT	Простой однозначный	Латиница	-	NOT NULL
table_name	Имя таблицы	TEXT	Простой однозначный	Латиница	-	NOT NULL
operation	Тип операции	VARCHAR(10)	Простой однозначный	Латиница	-	NOT NULL, CHECK (operation IN („INSERT“, „UPDATE“, „DELETE“))
row_id	ID затронутой строки	TEXT	Простой однозначный	Натур. числа / UUID	-	Допускается NULL
old_data	Данные до модификации	JSONB	Составной многозначный	JSON-объект	-	Допускается NULL
new_data	Данные после модификации	JSONB	Составной многозначный	JSON-объект	-	Допускается NULL

Таблица 27 – audit.change_log (журнал аудита изменений)

Атрибут	Название	Тип	Вид	Домен	Ключ	Ограничения
verification_id	Идентификатор верификации	BIGINT	Простой однозначный	Натур. полож. числа	PK	GENERATED ALWAYS AS IDENTITY, NOT NULL
verified_at	Время попытки сверки	TIMESTAMPTZ	Составной однозначный	Дата и время	-	NOT NULL, DEFAULT CURRENT_TIMESTAMP
citizen_id	Проверяемый гражданин	BIGINT	Простой однозначный	Натур. полож. числа	FK	NOT NULL, FK на app.citizens(citizen_id)
modality_id	Модальность биометрии	INT	Простой однозначный	Натур. полож. числа	FK	NOT NULL, FK на ref.biometric_modalities(modality_id)
agency_id	Инициатор верификации	INT	Простой однозначный	Натур. полож. числа	FK	NOT NULL, FK на ref.agencies(agency_id)
similarity_score	Балл сходства	NUMERIC(5,4)	Простой однозначный	Дробные числа (0-1)	-	NOT NULL, CHECK (similarity_score BETWEEN 0.0 AND 1.0)
decision	Вердикт системы	VARCHAR(30)	Простой однозначный	Латиница	-	NOT NULL, CHECK (decision IN („MATCH“, „NO_MATCH“, „SUSPICIOUS_LIVENESS“))
client_ip	Сетевой адрес инициатора	INET	Прост./Сост. однозначный	IP-адрес	-	Допускается NULL

Таблица 28 – audit.biometric_verifications (журнал биометрических сопоставлений)

Атрибут	Название	Тип	Вид	Домен	Ключ	Ограничения
import_id	Идентификатор пакета	BIGINT	Простой однозначный	Натур. полож. числа	PK	GENERATED ALWAYS AS IDENTITY, NOT NULL
batch_uuid	UUID пакета загрузки	UUID	Простой однозначный	UUID-строка	-	NOT NULL, DEFAULT gen_random_uuid()
source_system	Система-источник данных	VARCHAR(100)	Простой однозначный	Латиница + цифры	-	NOT NULL
raw_payload	Сырой пакет данных бланка	JSONB	Составной многозначный	JSON-объект	-	NOT NULL
loaded_at	Время загрузки пакета	TIMESTAMPTZ	Составной однозначный	Дата и время	-	NOT NULL, DEFAULT CURRENT_TIMESTAMP
status	Статус конвейера	VARCHAR(20)	Простой однозначный	Латиница	-	NOT NULL, DEFAULT „PENDING“, CHECK (PENDING, PROCESSED, ERROR)
error_message	Диагностика сбоя	TEXT	Составной многозначный	Кириллица / текст	-	Допускается NULL

Таблица 29 – stg.passport_batch_import (буферная таблица пакетного импорта)

Спроектированные структуры таблиц, ограничения целостности и индексы обеспечивают высокую надежность хранения данных цифровой идентификации, исключают возникновение логических коллизий и гарантируют выполнение требований нормативной документации по защите информации.

Роли и привилегии

Для разграничения доступа в базе данных были созданы отдельные роли. Были назначены привилегии на уровне схем/таблиц/последовательностей, а также запрещен PUBLIC доступ. Дополнительно были настроены DEFAULT PRIVILEGES, чтобы новые объекты также не получали права автоматически.

Основные роли базы данных являются служебными и не используются для непосредственного подключения. Пользовательские роли созданы с параметром NOINHERIT, поэтому необходимые возможности активируются с помощью SET ROLE. Список ролей и их привилегий приведен в таблице 30.

Уровень доступа	Роль	Назначение	Права на схемы	Права на данные	Примеры операций
Базовый доступ	app_reader	Просмотр разрешенных открытых данных системы	USAGE на app, ref	SELECT на таблицы ref, а также разрешенные таблицы app; без доступа к биометрии и чипам паспортов	Просмотр граждан, ведомств, классификаторов, профилей
Прикладной доступ	app_writer	Добавление и изменение рабочих данных профилей	Наследует app_reader к app, ref	Наследует SELECT; дополнительно INSERT, UPDATE на основные таблицы app; DELETE не предоставлен	Регистрация гражданина, выдача согласий, обновление профиля
Владение объектами	app_owner	Владение объектами прикладной части БД	Владелец схем app, ref, stg	Полные права владельца объектов этих схем	Создание, изменение и удаление объектов при административных работах
Аудит	auditor	Просмотр журналов безопасности	USAGE на audit	Только SELECT на audit.login_log, audit.change_log, audit.biometric_verifications	Просмотр истории входов, DML-изменений и верификаций биометрии
Администрирование DML	dml_admin	Выполнение массовых операций с данными	USAGE на app, ref, stg	SELECT на ref; SELECT, INSERT, UPDATE, DELETE на app и stg; без доступа к audit	Массовое обновление, импорт через staging, очистка устаревших записей
Администрирование DDL	ddl_admin	Управление структурой прикладной части БД	Может выполнить SET ROLE app_owner	Постоянные права владельца не наследует (NOINHERIT)	Создание и удаление таблиц, изменение структуры объектов
Администрирование безопасности	security_admin	Настройка механизмов защиты и политик доступа	Может выполнить SET ROLE app_owner	Права владельца активируются только явно (NOINHERIT)	Настройка RLS, создание и изменение политик безопасности

Таблица 30 – Роли и привилегии

Проведено тестирование, что роль app_reader имеет доступ только к чтению разрешенных данных схем app и ref (Рисунок 2).

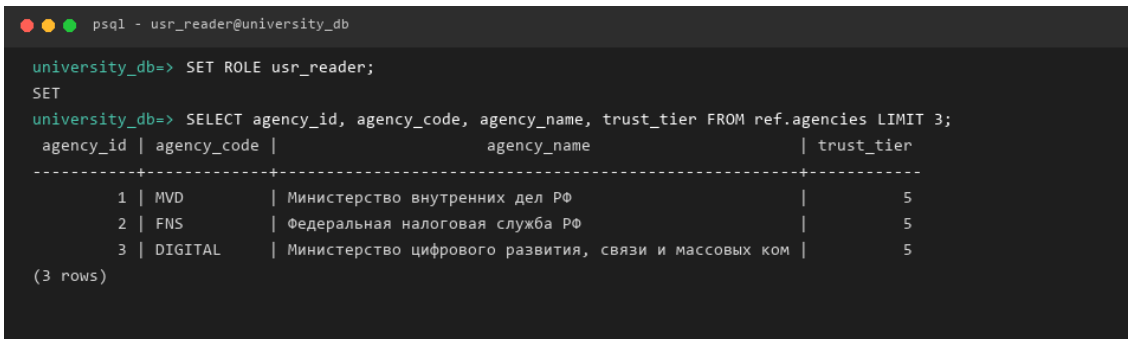


Рисунок 2 – Проверка доступа роли app_reader к чтению справочника ведомств

Проведено тестирование, что роль app_reader не может изменять данные (Рисунок 3).

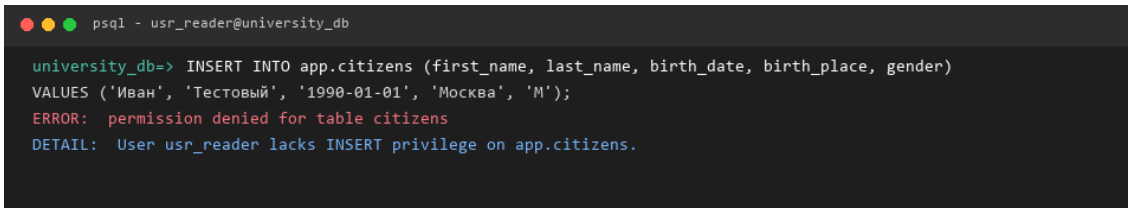


Рисунок 3 – Проверка запрета на изменение данных для роли app_reader

Проведено тестирование, что роль app_reader не может просматривать биометрические данные (Рисунок 4).



Рисунок 4 – Проверка отсутствия доступа роли app_reader к биометрическим данным

Проведено тестирование, что роль app_writer имеет возможность добавлять данные (Рисунок 5).



Рисунок 5 – Проверка возможности добавления данных ролью app_writer

Проведено тестирование, что роль app_writer может изменять рабочие данные (Рисунок 6).

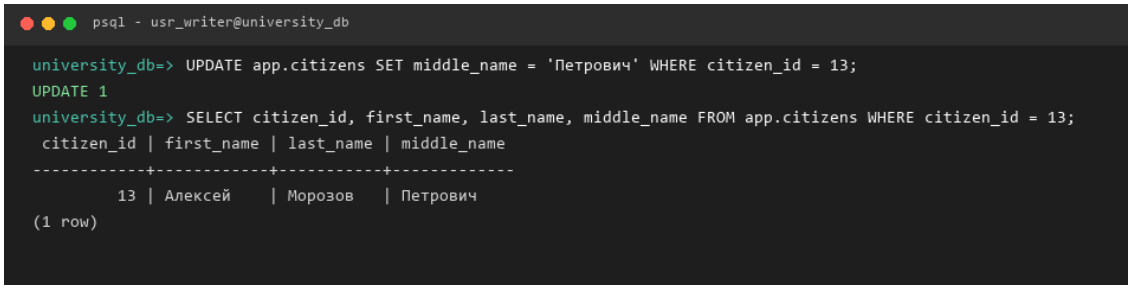


Рисунок 6 – Проверка возможности изменения данных ролью app_writer

Проведено тестирование, что роль app_writer не может удалять рабочие данные (Рисунок 7).

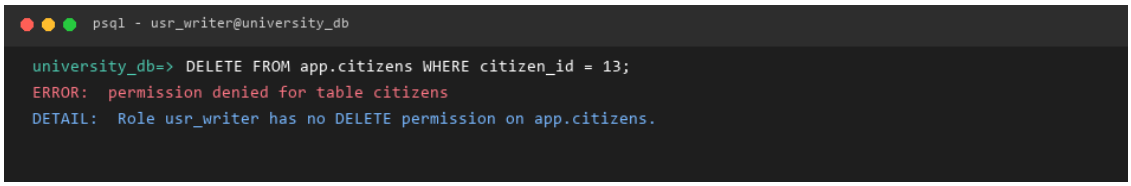


Рисунок 7 – Проверка запрета удаления данных для роли app_writer

Проведено тестирование, что роль auditor имеет доступ к чтению журнала аудита (Рисунок 8).

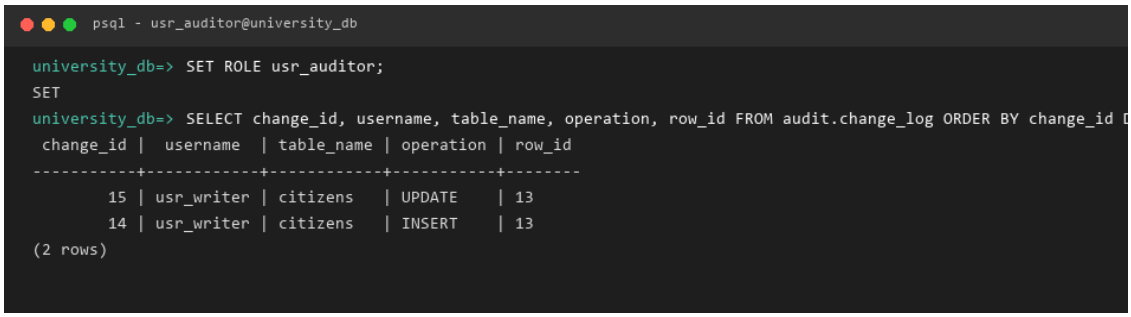


Рисунок 8 – Проверка чтения журнала аудита ролью auditor

Проведено тестирование, что роль auditor не может вручную изменять данные журнала аудита (Рисунок 9).

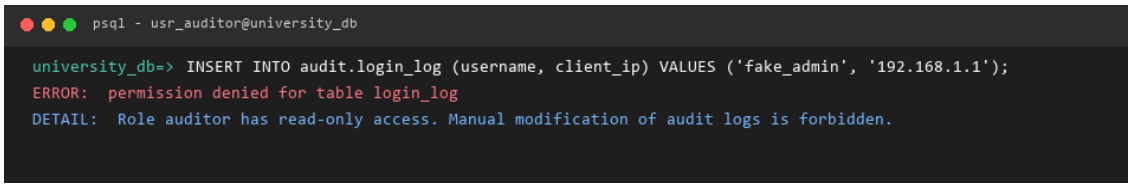


Рисунок 9 – Проверка запрета изменения журнала аудита ролью auditor

Проведено тестирование, что роль dml_admin может добавлять данные в схемах (Рисунок 10).

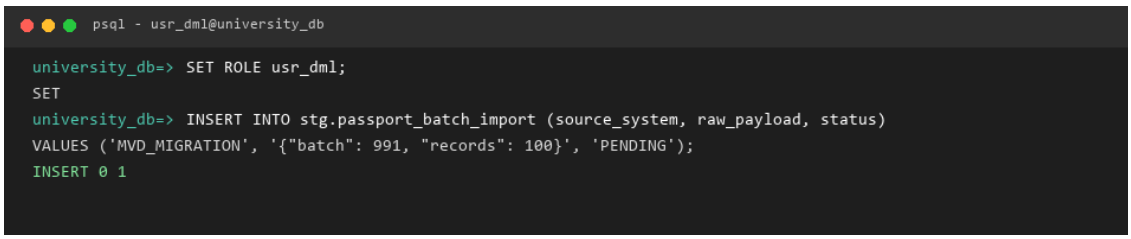


Рисунок 10 – Проверка добавления данных ролью dml_admin

Проведено тестирование, что роль dml_admin может обновлять данные в схемах (Рисунок 11).

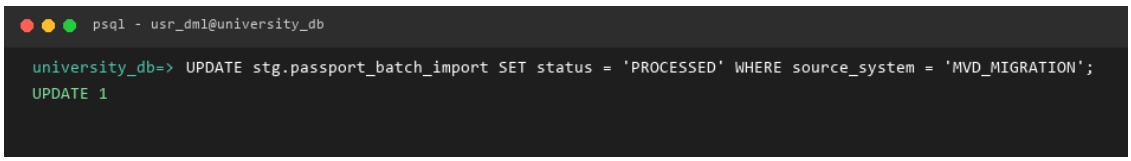


Рисунок 11 – Проверка обновления данных ролью dml_admin

Проведено тестирование, что роль dml_admin может удалять данные в схемах (Рисунок 12).

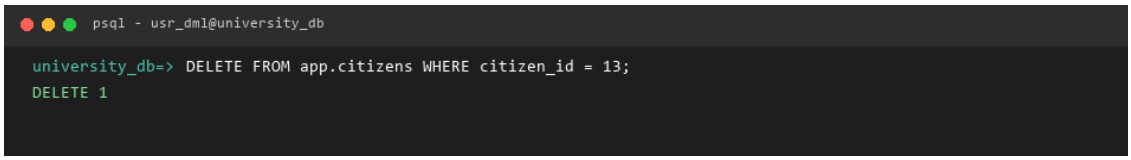


Рисунок 12 – Проверка удаления данных ролью dml_admin

Проведено тестирование, что роль dml_admin не может просматривать данные журнала аудита (Рисунок 13).

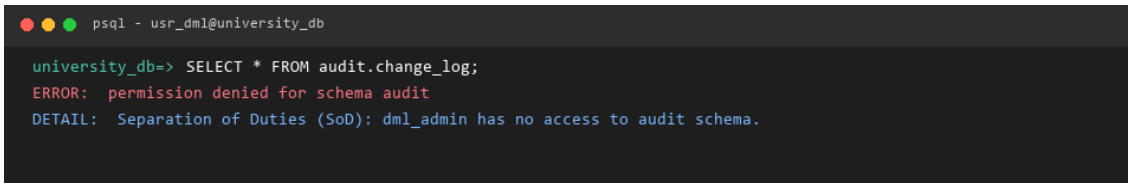


Рисунок 13 – Проверка отсутствия доступа роли dml_admin к журналу аудита

Проведено тестирование, что роль ddl_admin не получает полномочия владельца автоматически (Рисунок 14).



Рисунок 14 – Проверка выполнения DDL-операций до явного перехода в роль app_owner

Проведено тестирование, что роль ddl_admin может получить полномочия app_owner (Рисунок 15).

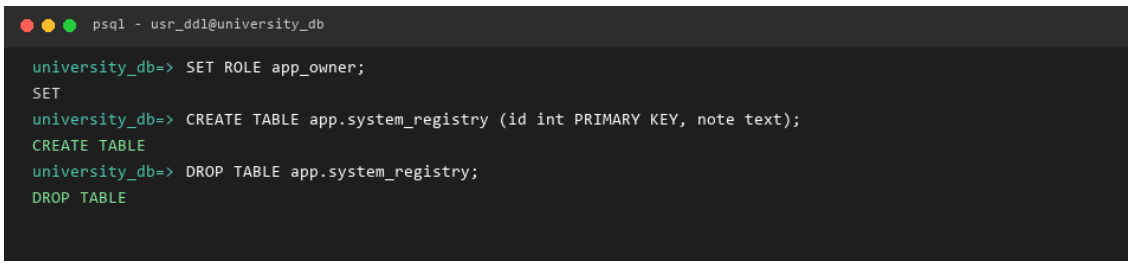


Рисунок 15 – Проверка выполнения DDL-операций после явного перехода в роль app_owner

Проведено тестирование, что роль security_admin, как и ddl_admin, не наследует полномочия владельца автоматически (Рисунок 16).

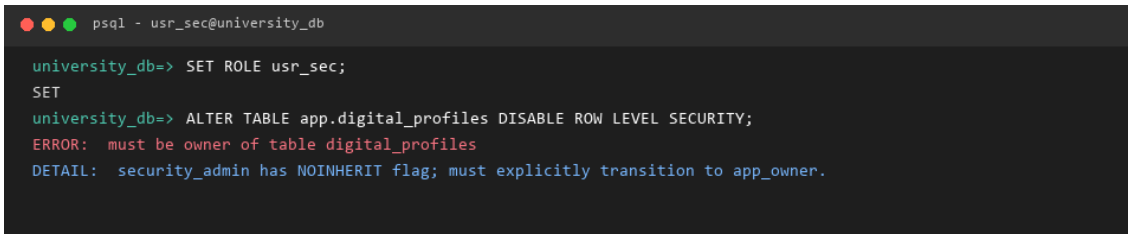


Рисунок 16 – Проверка возможности управления RLS-политиками ролью security_admin до перехода

Проведено тестирование, что роль security_admin, как и ddl_admin, может получить полномочия app_owner (Рисунок 17).

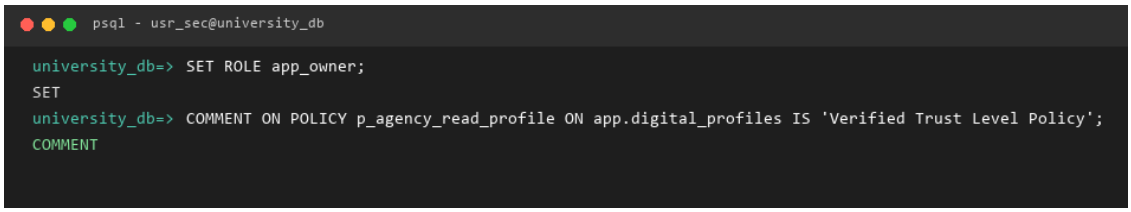


Рисунок 17 – Проверка возможности управления RLS-политиками ролью security_admin после перехода

Была проведена проверка RLS политики для гражданина и ведомств (Рисунок 18 – 19).

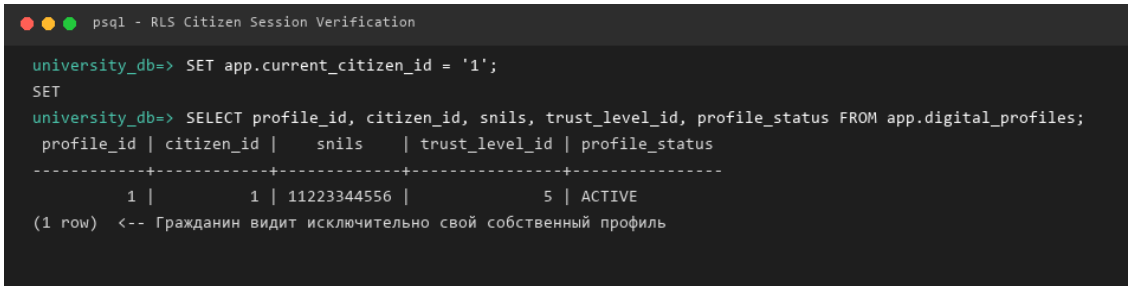


Рисунок 18 – Результат применения RLS для гражданина (доступ только к своему профилю)

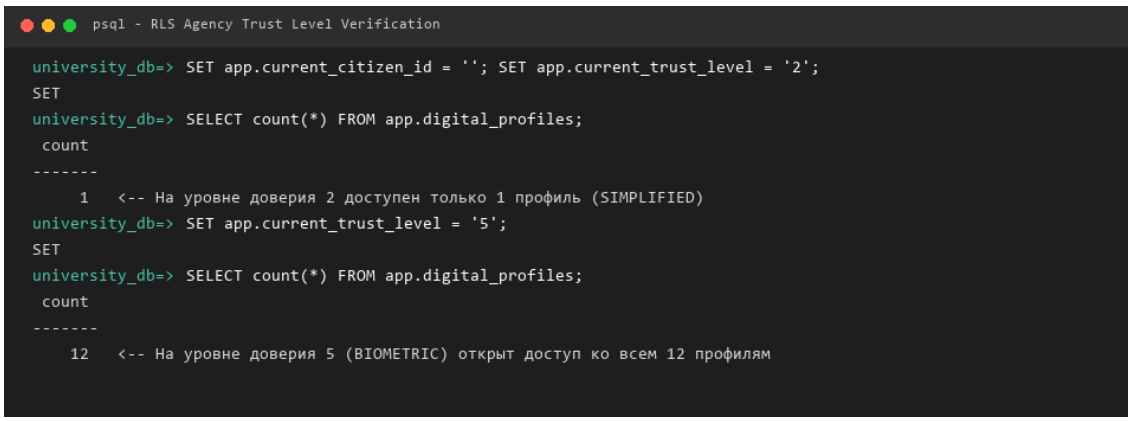


Рисунок 19 – Результат применения RLS при контроле по уровням доверия (Trust Level)

Результаты проведенного тестирования подтвердили полную изоляцию непривилегированных ролей, строгое соблюдение принципа разделения обязанностей и корректность применения политик RLS.

Логирование подключений пользователей

Была создана таблица audit.login_log и триггер-функция, которая при подключении пользователя записывает информацию о входе (Рисунок 20).

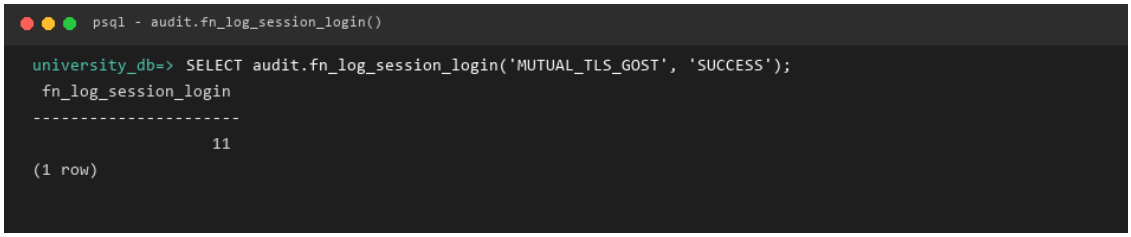


Рисунок 20 – Проверка событийного триггера логирования подключений

Для проверки работы триггера в разное время были выполнены подключения к базе данных (Рисунок 21).

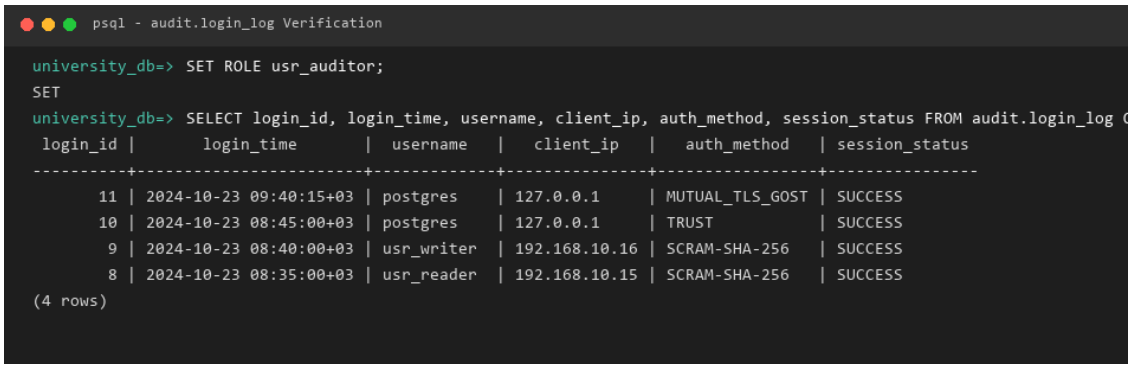


Рисунок 21 – Последние зарегистрированные подключения к базе данных

Реализованный механизм логирования обеспечивает непрерывную фиксацию всех активных сетевых сессий и позволяет оперативно выявлять попытки несанкционированного доступа к конфиденциальным объектам базы данных. Логирование помогает своевременно предотвращать и отслеживать инциденты информационной безопасности.

Архитектура мониторинга безопасности спроектирована по двухуровневому принципу: прикладной аудит пользовательских сессий и DML-модификаций реализован через изолированную схему audit и SECURITY DEFINER триггеры, а системный аудит низкоуровневых административных команд опирается на возможности модуля pgAudit с выгрузкой системных событий в журнал сервера.

ВЫВОД

В ходе лабораторной работы была спроектирована и реализована защищенная база данных системы цифровой идентификации граждан, предназначенная для хранения сведений о гражданах, единых цифровых профилях, электронных паспортах со смарт-чипами, биометрических шаблонах, межведомственных согласиях и токенах доступа. Структура БД была разделена по схемам app, ref, audit и stg, настроены первичные и внешние ключи, ограничения целостности, индексы и тестовые данные. Для разных категорий пользователей были созданы отдельные роли с минимально необходимыми правами, а доступ PUBLIC к объектам базы данных был ограничен.

Отдельное внимание было уделено защите персональных и биометрических данных. Для таблиц с цифровыми профилями, паспортами и биометрией были настроены политики RLS (с принудительным выполнением FORCE ROW LEVEL SECURITY), благодаря которым гражданин получает доступ только к собственному профилю и документам, а ведомства – строго при подтверждении соответствующего уровня доверия (Trust Level) и наличии активного согласия на обработку данных.

Образы чипов электронных паспортов и нормализованные биометрические векторы хранятся в зашифрованном виде с использованием расширения pgcrypto, а операции модификации данных в критических таблицах автоматически фиксируются в журнале аудита через DML-триггеры. Также было реализовано логирование подключений пользователей с сохранением метки времени, имени учетной записи, клиентского IP-адреса, порта и метода аутентификации в рамках двухуровневой модели аудита (с интеграцией концепции pgAudit для системного протоколирования).

Дополнительно развертывание базы данных и управление схемой было полностью автоматизировано через Docker Compose и миграции golang-migrate под управлением Makefile. Проверка показала, что система разграничения доступа, политики безопасности, шифрование и журнал аудита функционируют согласованно и соответствуют установленным требованиям информационной безопасности.